LABORATUVAR 3 · CLIOPACK TS-100 · TABAK KAPATMA

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad Ensar Daş | Grup | Tarih 23.10.2026

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır; insana zarar görünür kalır.

Ölçek: **L** 1 zor, özel bilgi + fiziksel erişim · 2 bilinen yöntemle · 3 kolay/yaygın | **S** 1 hafif/üretim kaybı · 2 tedavi gerektiren · 3 kalıcı/ölümcül | **E** 1 nadiren · 2 vardiyada birkaç kez · 3 her çevrimde/sürekli

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim → kapı → zincir → fiziksel sonuç)	L	S	E	Skor	Öncelik
R1 · Kim: servis firmasının paylaşılan parolasını ele geçiren dış saldırgan. **Kapı:** 7/24 açık 4G servis modemi (VPN/MFA yok). **Ne yapar:** HMI reçetesinde kapatma sıcaklığını/süresini ve gaz süresini düşürür. **Zincir:** film tam kaynamaz, MAP gazı kaçar, paketler sağlam görünüp sevk edilir. **Fiziksel sonuç:** taze et/hazır yemekte bakteri üremesi → **tüketicide gıda zehirlenmesi** (Listeria/Salmonella, ağır vakada ölüm).	2	3	3	18	Kritik
R2 · Kim: zararlı yazılım bulaşmış servis dizüstü bilgisayarı (teknisyen farkında değil). **Kapı:** mühendislik bağlantısı; interlock normal PLC yazılımında çözülmüş. **Ne yapar:** değiştirilmiş program yükler; "çekmece kapalı" koşulu yazılımda hep doğru sayılır. **Zincir:** operatör tabak yerleştirirken çevrim başlar, kafa iner. **Fiziksel sonuç: el/parmak ezilmesi + 150–200 °C plakada yanık** (kalıcı yaralanma).	1	3	3	9	Yüksek
R3 · Kim: içeriden hatalı/kötü niyetli kişi ya da enfekte USB. **Kapı:** HMI USB portu (reçete/firmware yükleme). **Ne yapar:** ısıtıcı ayar değerini ve dijital aşırı sıcaklık limitini yükseltir. **Zincir:** plaka aşırı ısınır, film ve tabak erir, duman ve yangın başlar; operatör sıkışan tabağı elle almaya çalışır. **Fiziksel sonuç: ağır yanık, yangın**, duman soluma.	1	3	1	3	Düşük S=3 → Yüksek

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1 En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

R1 (reçete manipülasyonu → hatalı kapatma → gıda zehirlenmesi): Kolay ulaşılan bir kapıdan geliyor (7/24 açık, paylaşılan parolalı modem), hiçbir emniyet fonksiyonu yakalamıyor (makine "normal" çalışıyor gibi görünüyor), ve zarar tek bir operatöre değil sevkiyattaki **binlerce tüketiciye** ulaşıyor.

2 S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

Evet: R3 (skor 3, Düşük bandında ama S=3).

- Risk Register'a ayrı bir **"S=3 bayrağı"** sütunu eklenir; bu satır skordan bağımsız olarak Yüksek önceliğe taşınır ve yönetim raporunun ilk sayfasında yer alır.
- Gereksinim yazılır: aşırı sıcaklık sınırlayıcısı **HMI'dan/USB'den ayarlanamayan, mühürlü, bağımsız bir donanım** olmalı.
- USB portu fiziksel olarak kilitlenir, reçete dosyası imza/hash kontrolünden geçer, parametre min/max sınırları PLC'de sabitlenir.
- Periyodik kontrol listesine "limit termostat fonksiyon testi" eklenir. Aynı mantık R2 için de geçerlidir (L=1, ama S=3 ve E=3).

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir. "Tesisin reçeteleri çalındı" senaryosunu bu yüzden listeye almadık; üç senaryonun üçü de hattaki ya da sofradaki **insana** ne olduğu ile bitiyor.

Risk matrisi — senaryoların konumu (S = 3 satırı)

	E = 1	E = 2	E = 3
L=1	3 · R3 yanık/yangın S=3 → öne alındı	6	9 · R2 el ezilmesi
L=2	6	12	18 · R1 gıda zehirlenmesi
L=3	9	18	27

Risk Register (EP 04)

ID	Varlık / kapı	Fiziksel sonuç	Skor	Mevcut önlem	Önerilen önlem	Sahip
R1	Servis modemi → HMI	Gıda zehirlenmesi	18	Paylaşılan parola	Jump server + VPN + MFA + kişisel hesap, varsayılan kapalı; reçete parametre sınırları; numune sızdırmazlık testi; reçete değişikliği log + onay	OT sorumlusu + Kalite
R2	Mühendislik dizüstü → PLC	El ezilmesi + yanık	9	Yok / bilinmiyor	Interlock'u Safety röle/PLC ile kablolu, PLC'den bağımsız çöz (PL d); program checksum karşılaştırma; özel bakım dizüstü bilgisayarı	Bakım + Emniyet müh.
R3	HMI USB	Yanık, yangın	3 S=3	Dijital termostat (varsayım)	Bağımsız, mühürlü donanım limit termostatı; USB kilidi; dosya imzası	Bakım

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.